Informe de Pentesting

Actividad A08: Hacking Ético

Índice

Índice de anexos **1**

6.1 Datos generales **2**

6.2 Pre-pentesting **2**
Alcance del trabajo . . . 2
Reglas de enfrentamiento (ROE) . . . 2
Autorización . . . 2
Metodología utilizada . . . 2

6.3 Hallazgos **2**
H-01: Listado de directorio con archivos internos expuestos . . . 2
H-02: Recurso SMB accesible sin autenticación . . . 3
H-03: Acceso SSH mediante contraseña débil . . . 3
H-04: Clave privada SSH legible por otros usuarios . . . 3

6.3 Hallazgos: Vulnversity **4**
H-05: Formulario de subida de archivos sin validación de tipo . . . 4
H-06: Binario con bit SUID en una ruta no estándar . . . 4

6.3 Estado de hallazgos y evidencias **4**

Anexo C: Hashes de las flags obtenidas **6**

Cliente: INSECUR S.A.

Contratista: Joaquin Herrera Gamez

DNI: 45360092

Username TryHackMe: herreragamezjoaquin

Sala de elección: Vulnversity

Branch: herrera-gamez-joaquin

Fecha de inicio: 14/10/2026

Fecha de cierre: 01/11/2026

Índice de anexos

- **Anexo A:** bitácoras de comandos, en la carpeta `bitacora/` del repositorio.
- **Anexo B:** capturas de evidencia, en la carpeta `evidencias/` del repositorio.
- **Anexo C:** hashes SHA-256 de las flags obtenidas, incluidos al final de este informe.
- **Anexo D:** declaración ética, firmada por separado.

6.1 Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Joaquín Herrera-Gámez
DNI	45360092
Username TryHackMe	herreragamezjoaquin
Email institucional	herreragamezjoaquin@uch.edu.ar
Sala de elección (Nivel 2)	Vulnversity
Branch en GitHub	herrera-gamez-joaquin
Fecha de inicio	14/10/2026
Fecha de cierre	01/11/2026

6.2 Pre-pentesting

Alcance del trabajo

Quedan dentro del alcance únicamente las máquinas de TryHackMe asignadas para este trabajo: Basic Pentesting (núcleo obligatorio) y Vulnversity (sala de elección). Quedan excluidos cualquier otro sistema, incluidas redes reales, la infraestructura de la facultad y cualquier host fuera del entorno de laboratorio.

Reglas de enfrentamiento (ROE)

- Las pruebas se realizan solo sobre las IPs asignadas por THM, con acceso a través de la VPN.
- Metasploit se usa solo contra la IP asignada por THM.
- Hydra se usa solo si la sala lo autoriza, con límites, y validando primero usuarios y políticas.
- Quedan prohibidos el phishing, los ataques MITM, la denegación de servicio y la fuerza bruta sin autorización de la sala.
- No se aplican técnicas sobre sistemas reales.
- No se definieron restricciones horarias por parte de la cátedra.
- Ante un incidente fuera del laboratorio, se informa de inmediato al docente.

Autorización

Se declara contar con autorización expresa de la cátedra para trabajar sobre los entornos de TryHackMe indicados en la guía, en el marco de la carta de autorización de INSECUR S.A.

Metodología utilizada

Se adopta OWASP (Web Security Testing Guide) como marco principal, por estar enfocado en aplicaciones web y servicios, que son el objetivo de las salas de este trabajo. Las fases de trabajo siguen el esquema general de Task 3: reconocimiento, escaneo, explotación, escalada de privilegios y post-explotación. Para los servicios de red que no son web (como SMB o SSH en Basic Pentesting), OWASP no cubre todo el alcance, por lo que se aplican esas mismas fases generales.

6.3 Hallazgos

H-01: Listado de directorio con archivos internos expuestos

- **Fase:** Escaneo / Enumeración
- **Descripción:** el servidor web permite listar el contenido de `/development/`, donde son legibles `dev.txt` y `j.txt`.
- **Componente afectado:** Apache 2.4.41, directorio `/development/`
- **Categoría (OWASP / CWE):** OWASP A05:2021; CWE-200
- **CVE:** No aplica

- **CVSS estimado:** Medio
- **Evidencia:** `bitacora/gobuster_80.txt`, `bitacora/dev_txt.txt`, `bitacora/j_txt.txt`. Captura pendiente (Anexo B).
- **Herramienta utilizada:** Gobuster, curl
- **Impacto CIA:** Confidencialidad
- **Salvaguarda propuesta:** deshabilitar el listado de directorios (`Options -Indexes`) y retirar los archivos internos del servidor.
- **Riesgo residual:** Bajo

H-02: Recurso SMB accesible sin autenticación

- **Fase:** Enumeración
- **Descripción:** el recurso `Anonymous` permite lectura sin credenciales.
- **Componente afectado:** Samba 4.15.13, recurso `Anonymous`
- **Categoría (OWASP / CWE):** OWASP A01:2021; CWE-284
- **CVE:** No aplica
- **CVSS estimado:** Medio
- **Evidencia:** `bitacora/enum4linux_nueva.txt`, `bitacora/smb_enum_users.txt`. Captura pendiente (Anexo B).
- **Herramienta utilizada:** smbclient, enum4linux
- **Impacto CIA:** Confidencialidad
- **Salvaguarda propuesta:** deshabilitar el acceso anónimo y exigir autenticación para todos los recursos compartidos.
- **Riesgo residual:** Bajo

H-03: Acceso SSH mediante contraseña débil

- **Fase:** Explotación
- **Descripción:** una cuenta del servicio SSH tiene una contraseña que figura en listas comunes de diccionario.
- **Componente afectado:** OpenSSH 8.2p1, puerto 22
- **Categoría (OWASP / CWE):** OWASP A07:2021; CWE-521
- **CVE:** No aplica
- **CVSS estimado:** Alto
- **Evidencia:** Captura pendiente (Anexo B).
- **Herramienta utilizada:** Hydra
- **Impacto CIA:** Confidencialidad, Integridad
- **Salvaguarda propuesta:** política de contraseñas robustas, límite de intentos con fail2ban y autenticación de dos factores.
- **Riesgo residual:** Bajo

H-04: Clave privada SSH legible por otros usuarios

- **Fase:** Post-explotación
- **Descripción:** la clave privada tiene permisos 644 y su passphrase es débil y recuperable por diccionario.
- **Componente afectado:** clave privada SSH de la cuenta comprometida
- **Categoría (OWASP / CWE):** OWASP A01:2021; CWE-732, CWE-521
- **CVE:** No aplica
- **CVSS estimado:** Crítico
- **Evidencia:** Captura pendiente (Anexo B).
- **Herramienta utilizada:** ssh2john, John the Ripper
- **Impacto CIA:** Confidencialidad, Integridad
- **Salvaguarda propuesta:** permisos `600`, passphrase robusta y revisión periódica de los directorios `.ssh`.
- **Riesgo residual:** Bajo

6.3 Hallazgos: Vulnversity

H-05: Formulario de subida de archivos sin validación de tipo

- **Fase:** Explotación
- **Descripción:** el directorio `/internal/` expone un formulario de subida de archivos que acepta extensiones no validadas en el servidor web, lo que permite cargar archivos que el servidor puede interpretar y ejecutar.
- **Componente afectado:** Apache 2.4.41, directorio `/internal/` (puerto 3333)
- **Categoría (OWASP / CWE):** OWASP A04:2021 (Insecure Design); CWE-434
- **CVE:** No aplica
- **CVSS estimado:** Alto
- **Evidencia:** `bitacora/vulnversity_gobuster.txt`. Captura de la sala completada en `evidencias/post/general_vulnver` Captura del formulario pendiente (Anexo B).
- **Herramienta utilizada:** Gobuster, curl, Burp Suite
- **Impacto CIA:** Confidencialidad, Integridad, Disponibilidad
- **Salvaguarda propuesta:** validar el tipo de archivo en el servidor (lista blanca de extensiones y de contenido), guardar las subidas fuera del directorio web y deshabilitar la ejecución de scripts en el directorio de subida.
- **Riesgo residual:** Bajo

H-06: Binario con bit SUID en una ruta no estándar

- **Fase:** Post-explotación
- **Descripción:** el binario `/bin/systemctl` tiene activado el bit SUID, lo que permite que un usuario sin privilegios lo ejecute con permisos de root. Esta configuración no es la esperada para ese binario y amplía la superficie de escalada de privilegios.
- **Componente afectado:** `/bin/systemctl` (bit SUID activo)
- **Categoría (OWASP / CWE):** OWASP A05:2021 (Security Misconfiguration); CWE-250
- **CVE:** No aplica
- **CVSS estimado:** Alto
- **Evidencia:** salida del comando `find / -perm -4000 -type f 2>/dev/null`, pendiente de guardar en `bitacora/`. Captura pendiente (Anexo B).
- **Herramienta utilizada:** find
- **Impacto CIA:** Confidencialidad, Integridad, Disponibilidad
- **Salvaguarda propuesta:** quitar el bit SUID del binario (`chmod u-s`), auditar periódicamente los binarios con SUID y aplicar el principio de mínimo privilegio.
- **Riesgo residual:** Bajo

6.3 Estado de hallazgos y evidencias

ID	Hallazgo	Texto del hallazgo	Evidencia	Estado
H-01	Listado de directorio en /development/	Completo	Captura y bitácora de gobuster	Completo
H-02	Recurso SMB anónimo	Completo	Captura del listado SMB con identidad visible	Completo
H-03	Acceso SSH con contraseña débil	Completo	Captura pendiente (sin acceso a la máquina de Basic Pentesting)	Parcial
H-04	Clave privada SSH legible	Completo	Captura pendiente (sin acceso a la máquina de Basic Pentesting)	Parcial

ID	Hallazgo	Texto del hallazgo	Evidencia	Estado
H-05	Formulario de subida sin validación	Completo	Captura del formulario con identidad visible	Completo
H-06	Binario con bit SUID	Completo	Captura pendiente (sin acceso a la sesión de la máquina)	Parcial

Hashes de flags (Anexo C): Vulnversity user flag y root flag completos. Basic Pentesting pendiente.

6.4 Resumen ejecutivo de hallazgos

Severidad Cantidad ID de hallazgos Crítico 1 H-04 Alto 1 H-03 Medio 2 H-01, H-02 Bajo 0 — Total 4

Durante la intervención se identificaron cuatro hallazgos sobre el entorno de INSECUR S.A. El más grave es la exposición de una clave privada SSH con permisos de lectura para cualquier usuario y una passphrase débil (H-04), que permitió el acceso no autorizado a una cuenta de usuario. Le sigue la autenticación SSH basada en una contraseña débil (H-03). Los dos hallazgos de severidad media son la exposición de un listado de directorio con archivos de desarrollo (H-01) y el acceso anónimo a un recurso SMB (H-02).

6.5 Post-pentesting: Recomendaciones

Recomendaciones técnicas (por criticidad):

H-04 (Crítico): revocar la clave privada expuesta y generar una nueva con passphrase robusta. Restringir sus permisos a 600 y guardarla fuera de directorios accesibles. H-03 (Alto): deshabilitar la autenticación por contraseña en SSH (PasswordAuthentication no), usar solo claves y limitar los intentos de acceso con fail2ban. H-02 (Medio): deshabilitar el acceso anónimo a SMB, exigir autenticación y revisar los permisos de cada recurso compartido. H-01 (Medio): desactivar el listado de directorios en el servidor web, retirar los archivos de desarrollo del entorno productivo y revisar qué queda publicado.

Recomendaciones administrativas:

Política de contraseñas y de gestión de claves con responsables definidos. Revisiones periódicas de la superficie de ataque y de los permisos de archivos. Capacitación al equipo sobre buenas prácticas de acceso y configuración segura. Repetir pruebas de penetración después de aplicar las correcciones.

7. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla

Al aplicar las correcciones de los hallazgos H-03 y H-04 sobre el servicio SSH (deshabilitar la autenticación por contraseña, rotar la clave privada y ajustar permisos), un error de configuración podría impedir el acceso remoto de los administradores o de los procesos automatizados que dependen de SSH. Lo mismo puede ocurrir al restringir SMB (H-02) o el listado de directorios del servidor web (H-01) si se bloquea un recurso que usan los sistemas internos.

Impacto sobre la continuidad del negocio

Se verían afectados el mantenimiento remoto de los servidores, los procesos de respaldo que usen SSH y cualquier aplicación interna que consuma los recursos SMB o web modificados. Como estimación, una interrupción de este tipo podría durar entre 1 y 4 horas si no hay un procedimiento de reversión ya probado.

Plan de respuesta

Activación: se detecta la falla por alertas de monitoreo, por reportes de los usuarios o por la imposibilidad de acceder a un servicio tras un cambio. Contención (primeros 15 minutos): se suspende el cambio en curso, se mantiene abierta una sesión de administración activa y se revierte la última modificación de configuración. Recuperación: se restaura la configuración anterior desde el respaldo versionado de /etc/ssh/sshd_config o del archivo de configuración correspondiente, se verifica el acceso y se vuelve a aplicar el cambio por etapas, con una ventana de prueba. Comunicación: se notifica al responsable de sistemas de INSECUR S.A. y a los usuarios afectados, con el estado del servicio y el tiempo estimado de restauración. Post-mortem: se documenta la causa de la falla, la acción correctiva y el cambio en el procedimiento de despliegue, para que no se repita.

RTO y RPO estimados

RTO (Recovery Time Objective): 4 horas. RPO (Recovery Point Objective): 24 horas, asumiendo respaldos diarios de la configuración.

Anexo C: Hashes de las flags obtenidas

Formato: flag_id sha256_hash

Vulnversity user flag d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956 Vulnversity root flag cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

Basic Pentesting: pendiente (no se pudo acceder a la máquina).